

UNIVERSIDAD DISTRITAL
FRANCISCO JOSÉ DE CALDAS

Actividad de Aprendizaje No. 2.1: Fase 2 del Proyecto Final

Nicolás Guevara Herrán (20211180026), Jhojan Stiven Aragón Ramírez (20221020060), y Daniel Orlando Villescas Mora (20221020065)

Maestría en Gestión y Seguridad de la Información, Facultad de Tecnología

Universidad Distrital Francisco José de Caldas

Arquitectura de Seguridad

Camilo Enrique Rocha Calderon

22 de septiembre de 2026

Bogotá, D.C.

Índice

Introducción **3**

1. Visión, Principios y Alcance de la Arquitectura **3**

2. Contexto de Negocio, Objetivos y Cumplimiento **3**

3. Evaluación del Estado Actual y Análisis de Brechas **3**

3.1. Efectividad (Capacidad de Reducción de Riesgo) 3

3.2. Madurez (Confiabilidad y Repetibilidad de Procesos) 4

3.3. Eficiencia (Relación Costo/Beneficio) 4

3.4. Análisis de Brechas (Gap Analysis) 5

Matriz Comparativa: Estado Actual vs. Estado Objetivo 6

Desglose Detallado de Brechas Técnicas y de Proceso 6

4. Modelo de Amenazas, Activos y Evaluación de Riesgos **8**

5. Arquitectura de Transición y Hoja de Ruta **8**

6. Métricas **8**

7. Conclusiones **8**

Introducción

1. Visión, Principios y Alcance de la Arquitectura

2. Contexto de Negocio, Objetivos y Cumplimiento

3. Evaluación del Estado Actual y Análisis de Brechas

Los ensayos previos y la entrega del primer corte dejan una línea base de hallazgos técnicos y conceptuales. Sobre esa base, esta sección contrasta la operación real del Centro de Control Integrado (CCI) con el estado objetivo y fija los requerimientos de arquitectura, procesos y seguridad necesarios para cerrar la brecha.

Siguiendo la metodología de evaluación propuesta por Moyle y Kelley (2020), este diagnóstico analiza la postura de seguridad bajo tres dimensiones complementarias: efectividad, madurez y eficiencia.

3.1. Efectividad (Capacidad de Reducción de Riesgo)

La efectividad mide la capacidad real de los controles instalados para mitigar los riesgos inherentes de nivel alto identificados en la operación (R1, R2, R3/R7 y R4/R6). En el estado actual, esta capacidad tiene debilidades operativas y arquitectónicas relevantes.

Control de acceso y autenticación (efectividad limitada). Aunque el sistema tiene inicio de sesión único (SSO) federado mediante Active Directory y ADFS, la autenticación multifactor (MFA) todavía no se exige de manera obligatoria en la totalidad de las consolas operativas. Adicionalmente, la matriz de roles RBAC se encuentra en proceso de consolidación, lo que mantiene abierta la exposición del Sistema de Despacho ante incidentes de suplantación de credenciales o ejecución indebida de órdenes de regulación.

Integridad de telemetría (efectividad baja). Las señales GPS/AVL se transmiten en tiempo real mediante canales celulares privados (APN). Sin embargo, al carecer de validación criptográfica en origen (firma o HMAC) y de filtros automáticos de plausibilidad física en la pasarela de ingestión, la capacidad para prevenir la inyección de tramas falsas o manipuladas es reducida. Esto permite que datos anómalos o adulterados puedan ingresar al motor de despacho y distorsionar la analítica operacional.

Disponibilidad y resiliencia (efectividad insuficiente). En el perímetro local se cuenta con una suite de seguridad consolidada (Fortinet: FortiGate, FortiSIEM y FortiAnalyzer). No obstante, toda la operación lógica y física se encuentra concentrada en una única sede (Edificio Elemento), sin un esquema probado de conmutación automática (*failover*) hacia un centro de contingencia (DRP) ni una redundancia híbrida completa con Google Cloud Platform (GCP). Por tanto, la sede es un Punto Único de Falla (SPOF), limitando severamente la capacidad de respuesta ante caídas de infraestructura.

3.2. Madurez (Confiabilidad y Repetibilidad de Procesos)

La madurez evalúa la formalización, documentación y repetibilidad de los procesos que soportan cada medida de seguridad:

- **Dominio de Gobierno de Identidades (IAM):** tiene una madurez en proceso de consolidación. El aprovisionamiento de cuentas opera de forma automatizada, pero los procesos de revisión trimestral de privilegios, auditoría de cuentas inactivas y segregación de funciones dependen de intervenciones manuales.
- **Dominio Criptográfico y Gestión de Dispositivos:** está en un nivel inicial de madurez. El proceso de gestión del ciclo de vida de certificados e identidades de los computadores de a bordo (unidades ITS) carece de procedimientos estandarizados y automatizados entre TransMilenio y los concesionarios de flota.
- **Dominio de Auditoría e Inmutabilidad:** tiene una madurez intermedia. Se realiza captura automática de eventos de despacho, pero la inmutabilidad de la bitácora mediante políticas WORM (*Write Once, Read Many*) en base de datos Oracle y la correlación en tiempo real en el SIEM se encuentran en fase de implementación procedimental.

3.3. Eficiencia (Relación Costo/Beneficio)

La centralización de la operación de los componentes Troncal, TransMiZonal y TransMiCable en la sala del CCI permite aprovechar mejor los recursos tecnológicos y humanos,

al reducir la necesidad de mantener salas de control y consolas independientes. Esta integración es una ventaja operativa, siempre que esté acompañada de controles adecuados y mecanismos de continuidad.

Sin embargo, la falta de controles preventivos automatizados, como la validación criptográfica de la telemetría y la exigencia de MFA en todas las consolas, incrementa la carga de trabajo de los equipos de monitoreo y TIC. En consecuencia, algunas actividades que podrían resolverse mediante controles automáticos requieren verificaciones manuales y análisis adicionales ante posibles anomalías.

Por último, la ausencia de un esquema de redundancia y recuperación debidamente probado es un riesgo operativo y económico. Una interrupción prolongada del centro principal podría afectar la regulación del transporte en toda la ciudad, por lo que resulta necesario evaluar la inversión en mecanismos de contingencia frente al impacto que tendría la indisponibilidad del servicio.

3.4. Análisis de Brechas (Gap Analysis)

El análisis de brechas compara de forma directa la arquitectura actual frente a la arquitectura objetivo. Su propósito es catalogar con claridad las deficiencias técnicas de infraestructura, software y criptografía, junto con las falencias de gobernanza y procedimientos que deben resolverse para llevar al CCI a un esquema de alta resiliencia y disponibilidad.

Matriz Comparativa: Estado Actual vs. Estado Objetivo

Tabla 1
Matriz comparativa entre el estado actual y el estado objetivo del CCI

Dominio clave	Estado actual	Estado objetivo
1. Control de Acceso y Gobierno de Identidades (IAM)	SSO corporativo (AD + ADFS), con MFA opcional o parcial en las 209 consolas y perfiles RBAC en proceso de consolidación sin segregación estricta entre monitoreo y supervisión.	Autenticación federada ADFS/SSO con MFA obligatorio en el 100 % de las consolas, matriz RBAC de privilegio mínimo y evaluación dinámica de políticas mediante motor PDP/PEP.
2. Integridad de Telemetría e Integración Geoespacial (GPS/AVL)	Telemetría de más de 10.500 buses enviada sobre APN privada, pero sin firma criptográfica en unidades ITS ni validación automática de plausibilidad física al ingresar al sistema.	Firma criptográfica (HMAC/X.509) en el borde embarcado, autenticación mutua, pasarela con filtros de plausibilidad física y enrutamiento seguro hacia RabbitMQ y Oracle Spatial.
3. Auditoría, Trazabilidad e Inmutabilidad (Bitácora CCI)	Políticas de almacenamiento WORM activas para resguardar la bitácora, pero con integración síncrona incompleta hacia las consolas y sin rutinas periódicas de verificación criptográfica.	Bitácora integrada de extremo a extremo con las consolas de despacho, sellado *hash* encadenado, marcas de tiempo sincronizadas (NTP) y correlación continua en FortiAnalyzer/FortiSIEM.
4. Disponibilidad, Resiliencia y Redundancia (Infraestructura)	Operación física y lógica concentrada en una única sede (Edificio Elemento) como Punto Único de Falla (SPOF), sin conmutación automática probada hacia un sitio alterno ni nube híbrida.	Arquitectura híbrida y redundante (GCP + Datacenter Local) sin SPOF, clúster perimetral Fortinet con mitigación DoS, *failover* automatizado y objetivo de recuperación de tiempo ($RTO \leq 15$ minutos).

Nota. Elaboración propia con base en el diagnóstico técnico del CCI.

Desglose Detallado de Brechas Técnicas y de Proceso

A partir de la comparación anterior, se establecen las intervenciones prioritarias divididas entre adaptaciones de ingeniería y formalización operativa:

Dominio de control de acceso y gobierno de identidades (IAM). En lo técnico, se requiere implementar el enrolamiento obligatorio y la validación del token MFA en el acceso al Sistema de Despacho (SIRCI/FMS). También es necesario ajustar los permisos RBAC para impedir que los usuarios con perfiles de monitoreo o consulta ejecuten comandos de regulación que no corresponden a sus funciones.

En los procesos, se busca automatizar la revisión periódica de privilegios y la desactivación de cuentas inactivas. Además, se debe establecer un procedimiento institucional de

auditoría trimestral que permita revisar las cuentas privilegiadas y detectar incompatibilidades entre las funciones asignadas.

Dominio de integridad de telemetría e integración geoespacial (GPS/AVL). Técnicamente, se necesita estandarizar los mecanismos criptográficos de los computadores de a bordo (unidades ITS) para garantizar la autenticidad de los mensajes transmitidos por los vehículos. De igual forma, se deben implementar mecanismos de cuarentena en el bus de eventos que permitan aislar los mensajes que no superen las validaciones de autenticidad o que presenten inconsistencias, como saltos de posición o velocidades imposibles, antes de incorporarlos a las bases de datos transaccionales.

En la operación, es necesario establecer acuerdos y procedimientos entre TransMilenio S.A. y los concesionarios para gestionar la emisión, renovación y revocación de los certificados digitales de la flota. También se deben definir pautas para tratar y reconciliar los datos cuando se presenten interrupciones de la cobertura celular.

Dominio de auditoría, trazabilidad e inmutabilidad de decisiones (bitácora CCI). La principal necesidad técnica es integrar las consolas operativas con la bitácora para registrar de manera completa y relacionada cada decisión, desde el dato de origen hasta el responsable, la instrucción impartida y el resultado obtenido. Asimismo, se propone implementar mecanismos de encadenamiento de *hashes* que permitan detectar posibles alteraciones en los registros mediante los sistemas de monitoreo.

Hacen falta auditorías periódicas que verifiquen la integridad criptográfica de los registros almacenados bajo el esquema WORM. También es necesario formalizar un procedimiento de cadena de custodia digital que defina cómo se deben extraer, conservar y entregar las evidencias operativas durante las auditorías internas o ante requerimientos de los entes de control.

Dominio de disponibilidad, resiliencia y redundancia (infraestructura del CCI). En la infraestructura, se plantea implementar la replicación de los datos y servicios críticos entre el centro de datos local del CCI y Google Cloud Platform (GCP), definiendo el esquema de redundancia que mejor se ajuste a los requisitos de continuidad. A esto se suma la automatización

de la conmutación del tráfico mediante los balanceadores de carga y los cortafuegos Fortinet, de modo que los servicios puedan recuperarse ante una falla del sitio principal.

Por último, es necesario formalizar los planes de recuperación ante desastres (DRP) y continuidad del negocio (BCP), y comprobar su efectividad mediante simulacros periódicos. Estos planes deben complementarse con manuales de contingencia y capacitación al personal del CCI para mantener la operación en condiciones degradadas y aplicar procedimientos de regulación de emergencia mediante radiocomunicaciones.

4. Modelo de Amenazas, Activos y Evaluación de Riesgos

5. Arquitectura de Transición y Hoja de Ruta

6. Métricas

7. Conclusiones

Referencias

Moyle, E., & Kelley, D. (2020). *Practical Cybersecurity Architecture: A guide to creating and implementing robust designs for cybersecurity architects*. Packt Publishing.